後量子密碼遷移之加密演算法自動化盤點框架研究

校系：輔仁大學 人工智慧與資訊安全學士學位學程　組別：第五組　組員：李昺圜、黃馨賢、余采芸
指導老師：勤業眾信 陳威棋 副總

背景介紹

危機：隨著量子計算發展，現行加密（RSA, ECC）面臨 Shor 演算法破解的巨大風險
趨勢：NIST 已啟動 PQC（後量子密碼）標準化，企業急需進行資產盤點與遷移
痛點：

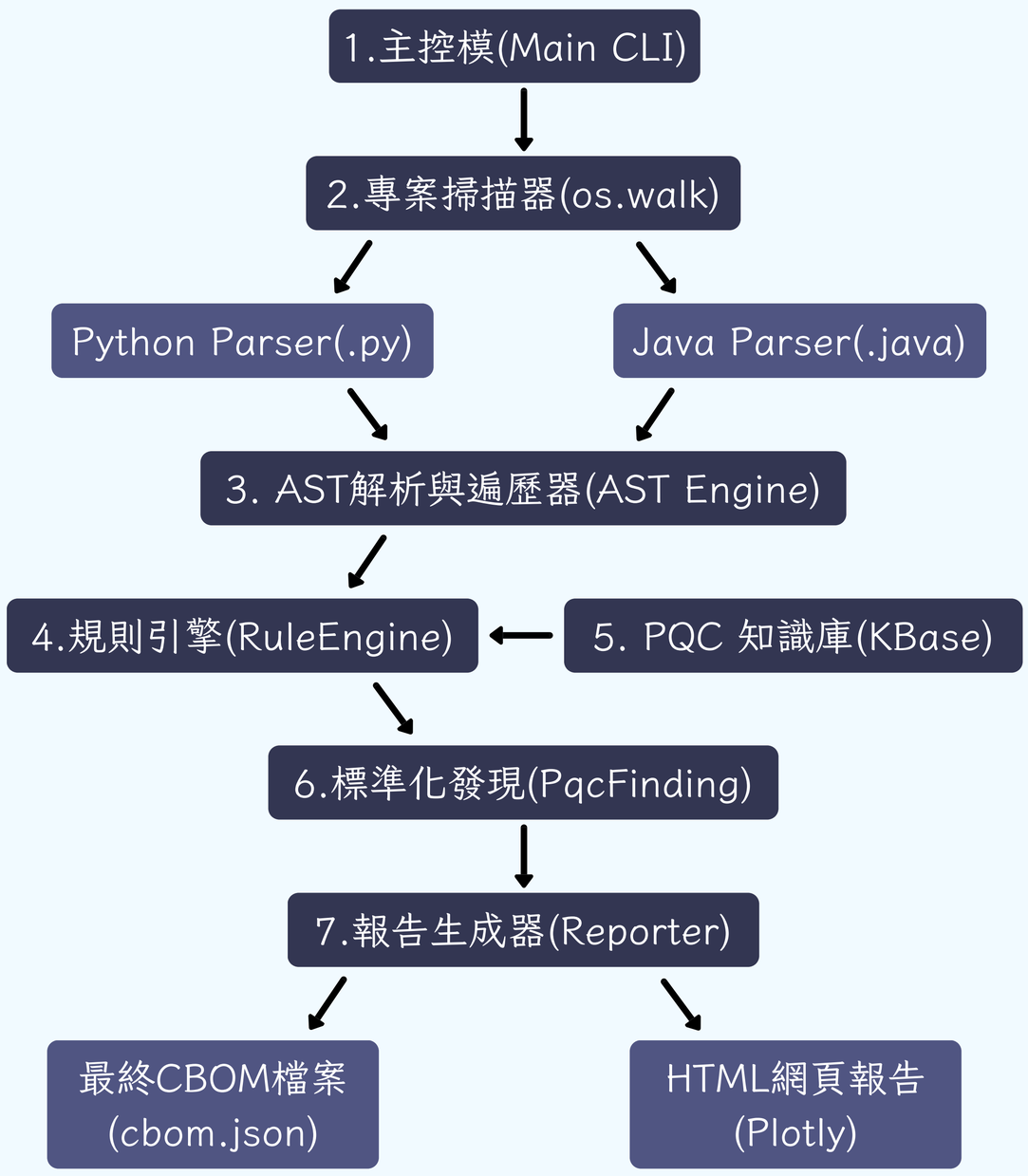
- 效率差：密碼資產盤點多依賴人工審查
- 準確性低：傳統工具（如 SonarQube）基於正則表達式，誤報率高
- 語義盲區：難以精確識別不安全參數配置（如 RSA-1024）

研究目的與重要性

目的：利用 AST 靜態分析技術，實現對跨語言程式碼中量子脆弱性資產的精確識別、定位與風險評估
重要性：

- 實現語義級精準掃描，降低誤報
- 實現跨語言盤點（Python 和 Java）
- 提供業界標準 CBOM 報告，利於系統整合
- HTML 網頁報告，將數據轉換為可視化的圓餅圖
- 加速企業 PQC 遷移決策

系統架構流程圖



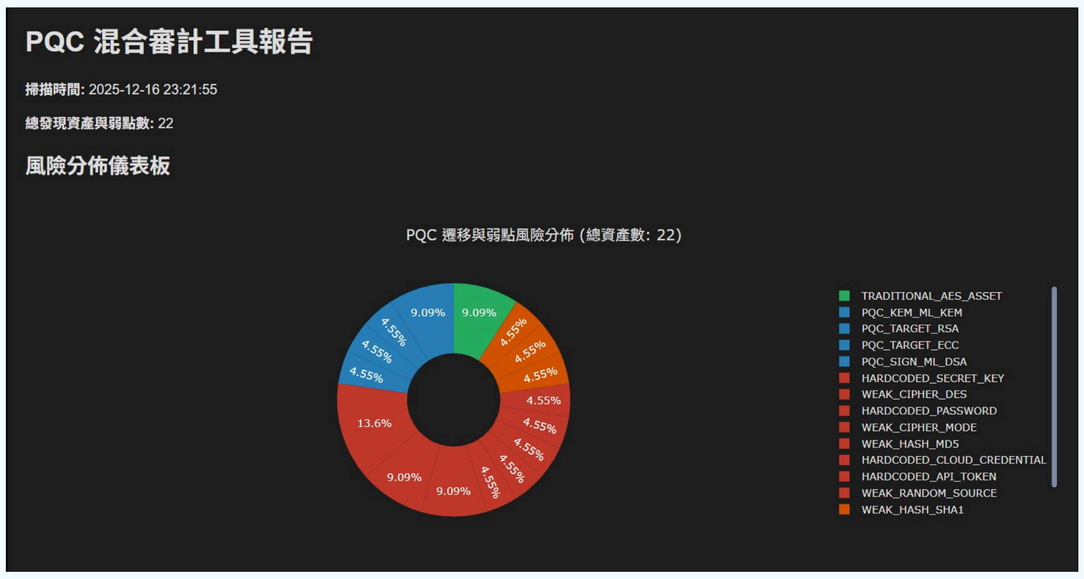
實作結果

挑戰與突破：

- 技術選型：放棄 tree-sitter，改用更底層的 AST 遍歷來實現參數級別的語義分析。
- 多語言整合：克服不同語言解析器的邏輯差異，建立統一的 PqcFinding 數據合約。
- 輸出優化：從終端機純文字輸出，升級至 Plotly 視覺化報告，大幅提升數據可讀性。

輸出成果：

- 標準化：輸出符合 CycloneDX (CBOM) 標準的 JSON 報告。
- 視覺化：Plotly 互動圖表，直觀呈現風險分佈與資產佔比。



詳細資產與漏洞清單

#	位置	類型	代碼片段	修補建議
1	.\test\pqc_test_suite.py:23	WEAK_HASH_SHA1	hashlib.sha1(data)	替換為 hashlib.sha256/sha3，SHA1 對碰撞攻擊是脆弱的。
2	.\test\pqc_test_suite.py:27	WEAK_HASH_MD5	hashlib.md5(data)	必須移除 MD5，替換為 SHA256。
3	.\test\pqc_test_suite.py:39	WEAK_CIPHER_DES	DES.new(key_des, DES.MODE_ECB)	停用 DES/3DES，改用 AES-256 GCM 模式。
4	.\test\pqc_test_suite.py:40	WEAK_CIPHER_DES	DES3.new(b'16bytekey16bytek', DES3.MODE_ECB)	停用 DES/3DES，改用 AES-256 GCM 模式。
5	.\test\pqc_test_suite.py:48	HARDCODED_SECRET_KEY	<ast.Constant object at 0x000002303B3C11D0>	絕對禁止在程式碼中寫死金鑰。請改用環境變數或 KMS。
6	.\test\pqc_test_suite.py:49	WEAK_CIPHER_MODE	AES.new(key, AES.MODE_ECB)	替換為 AES-256 GCM 或 CCM 模式，確保認證性。
7	.\test\pqc_test_suite.py:55	TRADITIONAL_AES_ASSET	AES.new(key, AES.MODE_GCM, nonce=bad_nonce)	這是一個抗量子資產。請確保 IV/Nonce 是正確生成的。
8	.\test\pqc_test_suite.py:60	TRADITIONAL_AES_ASSET	AES.new(key, AES.MODE_CBC, iv=static_iv)	這是一個抗量子資產。請確保 IV/Nonce 是正確生成的。
9	.\test\pqc_test_suite.py:68	WEAK_ASSET_RSA	RSA.generate(1024)	將密鑰長度至少增加到 2048/4096 bits，並規劃 PQC 遷移。
10	.\test\pqc_test_suite.py:72	PQC_TARGET_RSA	RSA.generate(2048)	量子脆弱：考慮替換為 CRYSTALS-Kyber (KEM) 或 Dilithium (Signature)。
11	.\test\pqc_test_suite.py:77	WEAK_ECC_CURVE	ECC.generate(curve='P-192')	使用 NIST P-256 以上。
12	.\test\pqc_test_suite.py:78	PQC_TARGET_ECC	ECC.generate(curve='P-256')	核心量子脆弱資產，建議替換為 CRYSTALS-Dilithium/Falcon。
13	.\test\pqc_test_suite.py:84	PQC_KEM_ML_KEM	模擬 PQC 函式庫調用，測試是否能識別 Kyber/Dilithium	PQC READY。請確保實作符合 FIPS 203 標準。
14	.\test\pqc_test_suite.py:89	PQC_KEM_ML_KEM	Kyber-768	PQC READY。請確保實作符合 FIPS 203 標準。
15	.\test\pqc_test_suite.py:94	PQC_SIGN_ML_DSA	Dilithium3	PQC READY。請確保實作符合 FIPS 204 標準。
16	.\test\pqc_test_suite.py:104	HARDCODED_SECRET_KEY	<ast.Constant object at 0x000002303B3BCC50>	絕對禁止在程式碼中寫死金鑰。請改用環境變數或 KMS。

結論

- PQC-AST-Scanner 成功驗證了以 AST 技術進行跨語言密碼資產盤點的可行性與優越性。
- 本系統不僅解決了傳統工具的誤報痛點，更透過標準化 CBOM 與視覺化報告，為企業 PQC 遷移提供了強有力的工具支持。
- 未來展望：將進一步導入 LLM 進行智能修復建議，並開發 Streamlit Web 介面，將工具升級為持續整合 (CI/CD) 流程中的自動化資安閘門。